

Prometheus AI

By Kingsman

Primary User Definitions & Personas

Prometheus AI serves two distinct user archetypes via a single backend ingestion engine.

1. Archetype A: The Executive / Non-Technical User

Target Profile: Finance Officer

Daily Workflow: Receives 20–40 vendor/supplier emails per day; approves 3–8 high-value supplier outbound remittance payments per week.

Technical Comfort Level: Uses standard web browsers and communication tools; possesses zero knowledge of DNS records, email routing headers, or cryptographic validation signatures.

Critical Need: A definitive, clear translation of security risk to protect the company's capital workflows.

2. Archetype B: The Security Analyst / Technical User

Target Profile: Junior Incident Response Analyst at a mid-size financial institution.

Daily Workflow: Triage internal system alerts, reviews flagged malicious URLs, investigates reported corporate phishing campaigns, and drafts weekly vulnerability remediation summaries to the CISO.

Technical Comfort Level: Understands complex application security behaviors, parses raw network telemetry data, and utilizes deep OSINT footprint analysis.

Critical Need: Forensic proof, attack vector visualization, and structured log outputs to support proactive defense and firewall configurations.

Interface Pattern: On-Demand Progressive Disclosure

To maintain a clean, distraction-free environment, the platform implements a Progressive Disclosure Layout. The system processes a submission identically for all users but splits the results page into two layers controlled by a high-visibility toggle switch **Simple view** ↔ **Analyst View**

❖ Simple View (Default Screen State)

This is the default view loaded immediately after a user submits a URL or email. It strips away all technical jargon to present a clear, high-level verdict.

- **Color-Coded Threat Badge:** A prominent status indicator mapping the final assessment level (e.g., **GREEN: SAFE**, **YELLOW: SUSPICIOUS**, or **RED: CRITICAL FINANCIAL THREAT**).
- **Natural Language Narrative:** A plain-language summary detailing the risk in a human-readable format, localized in both English and Sinhala.
- **Actionable Safety Playbook:** A step-by-step checklist telling the user exactly what to do next to prevent harm (e.g., “*Do not authorize any transactions,*” “*Call the sender using a verified, offline phone number.*”).

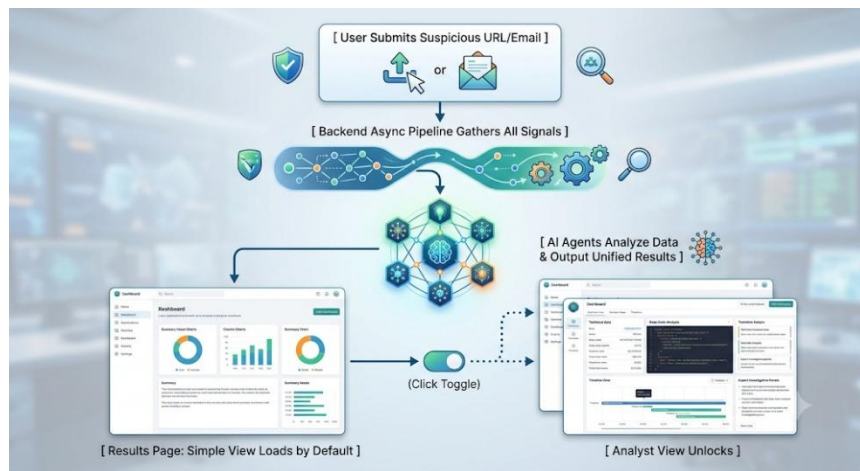
❖ Analyst View (Toggled Component)

Flipping the switch reveals the advanced security telemetry panel directly underneath the simple view, exposing the full technical depth of the engine.

- **Interactive Attack Propagation Graph:** A dynamic node network visualization mapping out exactly how the system predicts this specific attack chain would progress from entry to financial compromise.
- **Forensic Heuristics Grid:** An unvarnished data table displaying the raw metrics collected by the async background tasks:
 - *Domain Infrastructure:* Registration age, registrar info, and WHOIS query flags.
 - *Cryptographic Signatures:* SSL certificate issuance timelines and Certificate Authority profiles.
 - *Typosquatting Metric:* Levenshtein distance similarity scores against targeted legitimate institutions.
 - *Mail Routing Integrity:* Explicit verification of MIME parameters and Reply-To anomalies.
 - *Sandbox Behavioral Captures:* Live form POST destination data isolated during browser simulation.
- **Agent Logic Dissection:** Expandable tabs showing the raw structured JSON outputs and explicit reasoning logs from the individual backend AI agents.

Core Architectural Flow

The application architecture follows a direct, single-pass pipeline where the backend processes everything at once, leaving the frontend to control what is displayed



- **Submission:** The user inputs a suspicious email string or URL link into a single, clean input box.
- **Processing:** The FastAPI backend concurrently fires all static signal gathering and sandbox simulation tasks. The multi-agent layer evaluates these metrics and compiles them into a single, comprehensive JSON payload returned to the frontend.
- **Display:** The webpage defaults to the Simple View, immediately giving the user a clear threat status. If they want to inspect the background data, clicking the toggle unlocks the Analyst View on the fly without reloading the page or executing a new scan.

Prometheus AI: Phase 1 Technical Specification

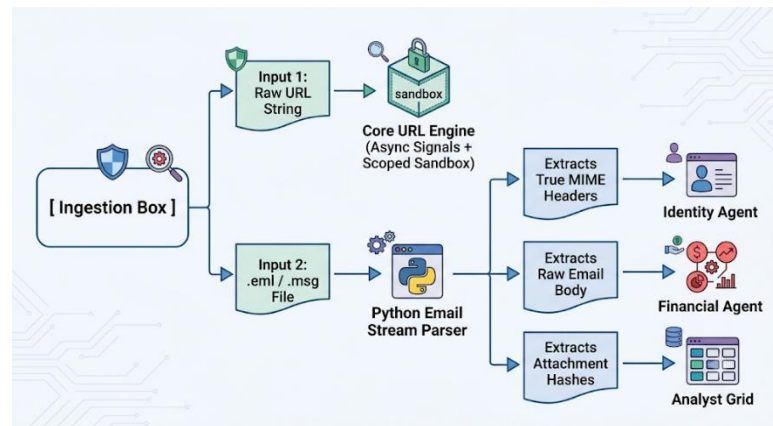
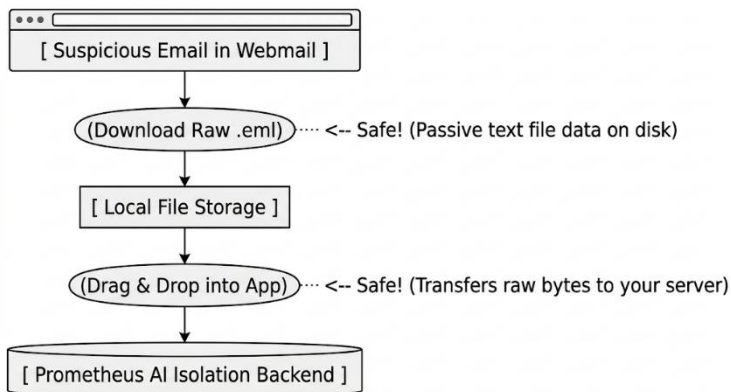
To guarantee data fidelity and prevent system parsing crashes on live inputs, Prometheus AI restricts its ingestion layer to two specific, well-defined formats:

Input Channel 1: Structured URL Strings

- *Specification:* Accepts any plain text string matching standard URI patterns (<http://> or <https://>).
- *Validation:* Runs a lookahead regex parse before passing the string to the async network signal engine. If the resolved IP maps to an RFC1918 private space, the connection is dropped immediately to prevent SSRF exploitation.

Input Channel 2: Local .eml / .msg File Uploads

- *Specification:* Rejects free-form plain text email body copy-pasting. Users tracking email threats must upload raw email export files directly into a dashboard dropzone component.
 - *Validation:* The FastAPI backend processes the incoming file stream through Python's native email.message libraries to isolate background routing strings and parse file attachments programmatically. This ensures maximum threat detection accuracy without requiring user intervention.



How email simulation work

Automated Attachment Processing & Document Analysis

To mitigate advanced Business Email Compromise (BEC) and invoice tampering threats, the backend pipeline automatically isolates and parses financial attachments discovered within uploaded .eml streams:

- **Volatile Attachment Extraction:** When an email file stream is processed, the backend maps multi-part MIME sections to locate target financial documents (specifically .pdf layouts). The raw binary data is held strictly in volatile system memory and is never written to the server's persistent disk storage.
- **Document Heuristic Parsing:** The system utilizes programmatic text extraction layers (pdfplumber / lightweight OCR) to extract text content arrays from the document layout. It explicitly isolates key tracking variables: printed vendor names, invoice tracking numbers, totals, and beneficiary bank account details.
- **Cross-Layer Verification Hook:** The extracted document values are bound directly into the agent context layer. The **Financial Manipulation Agent** runs a lookahead validation pass, checking for

critical BEC triggers: mismatches between the email sender's domain registration and the printed invoice brand headers, shifts in bank account destination arrays, and linguistic coercion or urgency indicators.

Framework and Tech Stack

- Agent frameworkLangChain — multi-agent pipelines, structured output parsing, tool integration
- LLM primaryClaude API (Sonnet) — better structured JSON consistency than GPT-4
- LLM fallbackOpenAI if rate limited
- Output validationPydantic models — schema enforcement on all agent outputs. Invalid = fallback, not crash
- Async strategyFastAPI async + httpx async — WHOIS + SSL + redirects run concurrently, not sequentially
- CachingRedis (or in-memory MVP) — WHOIS for same domain cached 24h
- DBSupabase (PostgreSQL + auto backups + free tier)
- FrontendNext.js + Tailwind CSS + React Flow (attack chain visualization)